



République Algérienne Démocratique et Populaire

Ministère de l'Enseignement Supérieur et de la Recherche Scientifique

Université Alger 1 – BENYOUCEF Benkhedda

Faculté des Sciences

Département Informatique

1^{ère} année Master

Module : Méthodologie de sécurité

(Enseignant : M. Rahmani)

Projet

Thème

**ANALYSE DES RISQUES (EBIOS-RM),
POLITIQUE DE SÉCURITÉ (PSSI) ET
PROCESSUS DE CONTINUITÉ D'ACTIVITÉ (PCA) DE LA
PLATEFORME PROGRES**

Réalisé par : F4t&Curi0us

Année universitaire : 2024/2025

Table des matières

1	Analyse des risques EBIOS-RM	1
1.1	Atelier 1 : Cadrage et socle de sécurité	1
1.1.1	Le périmètre d'étude :	1
1.1.2	Les biens essentiels :	1
1.1.3	Les biens supports :	1
1.1.4	Echelle de Gravité	2
1.1.5	Événement redouté :	2
1.2	Atelier 2 : Sources de risques	2
1.3	Atelier 3 : Scénarios Stratégiques	3
1.4	Atelier 4 : Scénarios Opérationnels	4
1.5	Atelier 5 : Traitement des Risques	6
2	Politique de Sécurité du Système d'Information (PSSI)	7
2.1	Phase 01 : Elements Strategiques	7
2.1.1	Recommandations	7
2.1.2	Enjeux strategiques	8
2.2	Phase 02 : Rédaction des règles	8
3	Plan de Continuité d'Activité (PCA)	9
3.1	Proc PCA1 : Sauvegarde et Restauration des Données	10
3.2	Proc PCA2 : Surveillance Continue des Activités	11
3.3	Proc PCA03 : Chiffrement des Données Sensibles	12
3.4	Proc PCA04 : Politique de Contrôle d'Accès	13
3.5	Proc PCA05 : Utilisation et Maintenance d'un Anti-Virus	14
3.6	Proc PCA06 : Audits réguliers de sécurité	15
3.7	Proc PCA07 : Plan de Formation et Sensibilisation	16
3.8	Proc PCA08 : Utilisation et Gestion d'un Firewall	17
3.9	Proc PCA9 : Déploiement de Serveurs de Secours et Basculement Automatique	18
3.10	Proc PCA:10 Gestion des Incidents (Prévention, Détection, Réponse)	20

Liste des tableaux

1	Échelle de gravité des risques	2
2	Tableau des événements redoutés et des risques associés	2
3	Analyse des sources de risque liées à l'inscription des étudiants	2
4	Analyse des sources de risque liées à l'inscription des étudiants	3
5	Analyse des sources de risque liées à l'inscription des étudiants	3
6	Analyse des scénarios stratégiques et des événements redoutés	3
7	Tableau des scénarios opérationnels et des risques associés	5

Team : F4t&Curi0us

Walid Chanane, Challal Lyes,
Hamzaoui Mohamed Anis, Mouchaal Sara,
Batoche Imane Lyna Nadine,
Hadj Ali Mehdi, Drouiche Amira,
Laroussi Abderrahmane, Ali Smail Souleimane

Résumé :

Ce document présente une analyse détaillée de la gestion des risques et de la continuité opérationnelle pour la plateforme PROGRES. Il se concentre sur trois aspects clés : une analyse des risques selon la méthode EBIOS-RM, l'élaboration d'une politique de sécurité des systèmes d'information (PSSI), et la conception d'un plan de continuité d'activité (PCA). L'analyse des risques, réalisée suivant la méthodologie EBIOS-RM (Expression des Besoins et Identification des Objectifs de Sécurité - Risk Management), s'articule autour de cinq ateliers complémentaires. Cette approche permet d'évaluer de manière systématique les vulnérabilités potentielles et les scénarios de menaces qui pourraient affecter la plateforme PROGRES. Le plan de continuité d'activité propose un ensemble de recommandations pratiques, d'actions concrètes et de procédures détaillées. Son objectif principal est d'assurer la disponibilité continue du système, sa capacité de résilience face aux perturbations, et la protection des ressources informationnelles et technologiques de l'organisation. L'ensemble de ces documents reflète une approche proactive de gestion des risques, visant à anticiper, prévenir et réduire les menaces potentielles tout en maintenant la performance opérationnelle de la plateforme PROGRES.

1 Analyse des risques EBIOS-RM

L'analyse des risques EBIOS-RM est une méthodologie complète et structurée en cinq ateliers, conçue pour identifier, évaluer et traiter les risques liés à un système d'information. L'atelier 1, "Cadrage et socle de sécurité," définit le périmètre de l'analyse, les objectifs de sécurité, les biens essentiels et les parties prenantes. L'atelier 2, "Sources de risques," identifie les acteurs et événements pouvant compromettre la sécurité. L'atelier 3, "Scénarios stratégiques," décrit les événements redoutés et leurs impacts potentiels sur les objectifs stratégiques. L'atelier 4, "Scénarios opérationnels," traduit les scénarios stratégiques en risques concrets pour les actifs et processus. Enfin, l'atelier 5, "Traitement des risques," propose des mesures de sécurité adaptées pour réduire, transférer ou accepter les risques identifiés. Cette approche garantit une sécurité robuste et une gestion proactive des menaces.

1.1 Atelier 1 : Cadrage et socle de sécurité

1.1.1 Le périmètre d'étude :

Les trois (03) fonctionnalités de PROGRES :

- Inscription des étudiants.
- Paiement électronique.
- Gestion des notes d'examens et contrôle continu (introduction, consultation et recours).

1.1.2 Les biens essentiels :

1. Inscription des étudiants
 - Données personnelles des étudiants.
 - Documents administratifs numériques.
2. Paiement électronique
 - Journal des transactions.
3. Gestion des notes d'examens et contrôle continu (introduction, consultation, et recours)
 - Données académiques des étudiants.
 - Données des enseignants.

1.1.3 Les biens supports :

- Infrastructure matérielle (Serveurs, Ordinateurs, Réseaux).

1. Inscription des étudiants
 - Interface d'inscriptions.
2. Paiement électronique
 - Passerelle de paiement.
3. Gestion des notes d'examens et contrôle continu (introduction, consultation, et recours)
 - Plateforme de saisie des notes.
 - Portail de consultation des notes.
 - Interface de gestion des recours.

1.1.4 Echelle de Gravité

Gravité
0 - Normale
1 - Moyenne
2 - Risquée

TABLE 1 – Échelle de gravité des risques

1.1.5 Événement redouté :

Code	Événement redouté (ER)	Description	Gravité
1	Perte de données	Perte totale ou partielle de l'ensemble des données.	2
2	Vol de données	Vol partiel ou total, une copie/publication illégale des données.	2
3	Altération des données	Une modification non autorisée des données.	1
4	Interruption des services	Indisponibilité des services d'inscription et paiements ..etc	1
5	Falsification de documents administratifs	Perte d'authenticité des certificats d'inscription ou des reçus.	1
6	Non-conformité réglementaire	Le non-respect de normes législatives.	2

TABLE 2 – Tableau des événements redoutés et des risques associés

1.2 Atelier 2 : Sources de risques

Inscription des Étudiants :

Source de risque	Description	Objectif de sécurité
Personnel malveillant	Un employé tente d'altérer, supprimer ou de voler des données d'inscription.	Intégrité, Disponibilité, Confidentialité
Étudiant malveillant	Une tentative de manipuler ses informations ou celles d'autres étudiants.	Intégrité, Disponibilité, Confidentialité
Personnel non malveillant	Mauvaise saisie ou suppression accidentelle.	Disponibilité, Intégrité

TABLE 3 – Analyse des sources de risque liées à l'inscription des étudiants

Païement électronique :

Source de risque	Description	Objectif de sécurité
Personnel malveillant	Manipulation de journal de transaction par un employé.	Intégrité
Étudiant malveillant	Tentative de paiement frauduleux ou exploitation de failles dans le système.	Intégrité
Personnel non malveillant	Traitement incorrect des transactions (mauvaise saisie, validation d'une opération incorrecte).	Intégrité

TABLE 4 – Analyse des sources de risque liées à l'inscription des étudiants

Gestion des Notes :

Source de risque	Description	Objectif de sécurité
Personnel malveillant	Modification volontaire des notes ou suppression des données d'étudiants.	Intégrité, Disponibilité
Étudiant malveillant	Tentative de modifier ses propres notes ou celles d'autres étudiants par intrusion.	Confidentialité, Intégrité, Disponibilité, Authentification
Personnel non malveillant	Erreurs de manipulation (ex. modification ou suppression accidentelle de notes).	Intégrité, Disponibilité

TABLE 5 – Analyse des sources de risque liées à l'inscription des étudiants

1.3 Atelier 3 : Scénarios Stratégiques

TABLE 6 – Analyse des scénarios stratégiques et des événements redoutés

Code	Événement redouté	Sources de risques	Description	Gravité
R1	Perte de données	PM	Suppression de toutes les données ⇒ base de données vide ⇒ poursuite judiciaire	2
R2	Perte de données	EM	Une attaque informatique permettant la suppression de toutes les données ⇒ base de données vide ⇒ poursuite judiciaire	2
R3	Perte de données	PNM	Suppression de toutes les données ⇒ base de données vide ⇒ poursuite judiciaire	2

Code	Événement redouté	Sources de risques	Description	Gravité
R4	Vol de données	PM	Un employé parvient à exfiltrer des données sensibles des étudiants (nom, matricule, etc.) via une faille ou une action malveillante. ⇒ poursuite judiciaire	2
R5	Vol de données	PNM	Piratage de son propre compte ⇒ poursuite judiciaire	2
R6	Vol de données	EM	Une attaque informatique permettant de voler des données ⇒ atteinte à la crédibilité	0 à 1
R7	Interruption des services	EM	Une attaque informatique rend un service indisponible pour tous les utilisateurs. ⇒ atteinte à la crédibilité	0 à 1
R8	Interruption des services	PM	Une panne technique exploitée rend un service indisponible pour tous les utilisateurs. ⇒ atteinte à la crédibilité	0 à 1
R9	Interruption des services	PNM	Une panne technique causée involontairement rend un service indisponible. ⇒ atteinte à la crédibilité	0 à 1
R10	Altération des données	EM	Un étudiant modifie les notes des examens en exploitant des failles. ⇒ atteinte à la crédibilité	0 à 1
R11	Altération des données	PM	Un employé modifie frauduleusement les notes des examens en exploitant ses privilèges. ⇒ poursuite judiciaire	2
R12	Non-conformité réglementaire	PNM	Le système ne respecte pas les normes législatives, ⇒ des sanctions légales et des plaintes des utilisateurs.	2

1.4 Atelier 4 : Scénarios Opérationnels

Code	Scénario Stratégique	Description	Gravité
R1.1	R1	Suppression de la base de données (par requête SQL).	2
R1.2	R1	Formatage du serveur de base de données.	2
R1.3	R1	Destruction du matériel (disque dur).	0 à 1
R1.4	R1	Injection d'un malware.	2
R2.1	R2	Une attaque ransomware entraîne une perte potentielle des données des serveurs en les chiffrant, rendant leur récupération impossible sans un mécanisme de restauration ou paiement de rançon.	1 à 2
R4.1	R4	Un employé interne exporte des données sensibles à partir du système sans autorisation légitime.	2
R4.2	R4	Installation d'un keylogger.	1 à 2
R6.1	R6	Un étudiant exploite une vulnérabilité dans l'application web pour exfiltrer des données personnelles via une injection SQL.	2
R6.2	R5 / R6	Un étudiant obtient un accès illégitime au compte d'un enseignant via une attaque de phishing.	2
R6.3	R6	Injection d'un malware via e-mail.	2
R6.4	R6	Une attaque sur un réseau Wi-Fi non sécurisé permet d'intercepter des sessions de connexion au système PROGRES.	2
R7.1	R7	Une attaque DDoS cible le serveur principal, provoquant une saturation du réseau et rendant le portail d'inscription inaccessible.	0 à 1
R7.2	R7	Une attaque ransomware provoque une indisponibilité prolongée du service en chiffrant les données critiques des serveurs, empêchant leur utilisation immédiate.	1 à 2
R9.1	R9	Une mauvaise configuration du serveur provoque l'indisponibilité du service d'inscription pendant plusieurs heures.	0 à 1
R10.1	R10	Une faille dans les permissions permet à un étudiant avec des droits limités de modifier les notes d'examens sans contrôle..	0 à 1
R12.1	R12	L'absence d'un mécanisme explicite de consentement des utilisateurs pour le traitement des données enfreint les droits des utilisateurs.	2
R12.2	R12	Les journaux d'accès ne sont pas conservés suffisamment longtemps, rendant impossible une analyse d'audit demandée par les autorités..	2

5
TABLE 7 – Tableau des scénarios opérationnels et des risques associés

1.5 Atelier 5 : Traitement des Risques

R1.1 , R1.2 , R1.3 et R2.1 :

- Mettre en oeuvre un plan de sauvegarde régulier avec des sauvegardes incrémentales et complètes.
- Tester régulièrement la restauration des sauvegardes.
- Conserver les sauvegardes dans des emplacements physiquement distincts.
- Mettre en place une surveillance continue des activités sur les serveurs.

R1.4 , R6.1 et R6.3 :

- Utiliser un anti-virus et le maintenir (manuellement) à jour.
- Mettre en place un chiffrement des données sensibles (en transit et au repos).
- Déployer un SIEM pour détecter les activités suspectes.
- Effectuer des audits réguliers de sécurité.
- Restreindre l'accès aux données sensibles selon le principe du moindre privilège.

R4.2 et R6.2

- Etablir un plan de formation et sensibilisation.
- Utiliser un firewall.
- Interdire le clique sur les liens.
- Utiliser un anti-phishing (module installé sur la messagerie).
- Activer une double authentification pour les comptes des enseignants.

R6.4

- Implémenter le protocole HTTPS/TLS sur tous les services.
- Ajouter des certificats SSL robustes pour les services.
- Ajouter un chiffrement end-to-end pour les échanges critiques.

R7.1

- Utiliser un pare-feu applicatif (WAF) pour bloquer les attaques DDoS.
- Déployer un système de répartition de charge (Load Balancer).

R9.1 :

- Former le personnel à gérer les pannes critiques.
- Déployer des serveurs de secours ainsi qu'un processus de basculement automatique en cas d'interruption du system.

R10.1

- Mettre en place des journaux d'audit détaillés sur toutes les modifications des notes.
- Limiter les permissions des utilisateurs à leurs besoins stricts.
- Activer des contrôles d'intégrité sur les bases de données académiques.
- Mettre en place des mécanismes de détection des altérations non autorisées.
- Restreindre les accès aux fichiers historiques à des utilisateurs vérifiés.

R12.1 et R12.2

- Nommer un délégué à la protection des données (DPO).

- Former les employés aux règles de conformité en matière de protection des données personnelles et de sécurité des transactions financières.
- Maintenir un registre des activités de traitement des données.
- Implémenter une politique stricte de journalisation.
- Sauvegarder les journaux sur des serveurs sécurisés et hors site.
- Mettre en place des alertes automatiques en cas de suppression ou corruption des logs..

2 Politique de Sécurité du Système d'Information (PSSI)

La politique de sécurité (PSSI) est un document central qui définit les orientations et les règles pour assurer la protection des systèmes d'information. Elle se compose de deux phases principales : les éléments stratégiques, qui fixent les objectifs et enjeux de sécurité en cohérence avec la vision de l'organisation, et la rédaction des règles, qui formalise les directives opérationnelles pour garantir la sécurité au quotidien.

2.1 Phase 01 : Elements Strategiques

2.1.1 Recommendations

- Définir une politique de contrôle d'accès.
- Interdire les mise à jour automatiques.
- Interdire les cliques sur les liens.
- Interdire les flash disques personnelles.
- Mettre en place une structure de gouvernance dédiée à la sécurité des SI (DSSI).
- Définir des politiques de sécurité claires et alignées avec les exigences réglementaires.
- Impliquer la direction générale dans la supervision de la sécurité.
- Former régulièrement les employés sur les bonnes pratiques de sécurité, tout en les sensibilisant aux risques spécifiques tels que le phishing, les ransomwares et la gestion des mots de passe.
- Prévoir des plans de continuité et reprise d'activité (PCA et PRA).
- Mettre en place des sauvegardes régulières, externalisées et testées.
- Développer une architecture sécurisée pour garantir la disponibilité des services critiques.
- Déployer des solutions de protection (antivirus, pare-feu, WAF, DLP).
- Intégrer des outils de supervision de la sécurité (SIEM) pour une détection proactive des incidents.
- Créer un processus clair de gestion des incidents (prévention, détection, réponse(Play-book)).
- Maintenir une documentation centralisée des incidents pour faciliter les audits et retours d'expérience.

2.1.2 Enjeux stratégiques

- Protéger les données académiques (notes, inscriptions) et personnelles des utilisateurs.
- Les données ne peuvent pas être partagées en dehors du système.
- Le système doit permettre à chaque acteur de faire exactement ce qui est autorisé de faire.
- Les outils doivent être maintenus à jour.
- Les données sont échangées entre les acteurs.
- Respecter les obligations réglementaires pour éviter des sanctions financières et juridiques.
- Maintenir l'accèsibilité des services critiques, comme les inscriptions, la gestion des notes, et les paiements en ligne.
- Limiter l'impact des incidents majeurs grâce à des plans PCA/PRA adaptés.
- Offrir un environnement numérique fiable pour les étudiants, enseignants et partenaires financiers.
- Répondre rapidement et efficacement en cas d'incident pour préserver la réputation de l'établissement.
- Anticiper les attaques ciblant le système PROGRES (ex : ransomwares, phishing).
- Identifier et corriger rapidement les vulnérabilités techniques et organisationnelles.
- Allouer les ressources humaines, techniques et financières de manière optimale pour maximiser l'efficacité des mesures de sécurité.
- Prioriser les investissements en fonction des risques identifiés par la méthode EBIOS-RM.

2.2 Phase 02 : Rédaction des règles

Article 1 : Chaque utilisateur doit disposer d'un compte unique avec des droits d'accès définis selon le principe du moindre privilège.

Les mots de passes doivent être changé tous les sept (07) mois.

Article 2 : Toute activité suspecte détectée doit être signalé au Responsable Sécurité dans un délai maximum de 24 heures.

Article 3 : Les employes doivent être sensibilisé annuellement sur les bonnes pratiques de cybersécurité.

Article 4 : Les données d'inscription doivent être vérifiées avant validation pour éviter les fraudes.

Article 5 : Toute modification des informations personnelles nécessite une validation par double authentification (MFA).

Article 6 : Les paiements doivent être effectués via une passerelle conforme aux normes législatives.

Article 7 : Les enseignants doivent accéder à la plateforme via un réseau sécurisé.

Article 8 : Toute modification des notes nécessite une justification qui sera consignée dans les logs.

Article 9 : Les recours doivent être traités uniquement par les enseignants autorisés et validés par le département académique.

- Article 10 :** Les correctifs de sécurité doivent être appliqués dans un délai maximum de 7 jours après leur publication.
- Article 11 :** Les données personnelles doivent être traitées conformément aux normes législatives.
- Article 12 :** Toute évolution majeure du système doit être validée par le comité de sécurité.
- Article 13 :** Il est strictement interdit de cliquer sur n'importe quel lien reçu par email.
Les liens reçus par email doivent être déclarés à la structure responsable.
Les procédures de déclaration et traitement sont définies dans le plan de continuité d'activité.
- Article 14 :** Les mises à jour automatiques doivent être désactivées sur les logiciels du système.
Les mises à jour doivent être faites manuellement chaque fin de semaine.
- Article 15 :** Les données classées modifiables peuvent être directement modifiées sur le système en présentant un justificatif valable. La modification des données classées intégrées est soumise à des procédures administratives.
- Article 16 :** Les données classées confidentielles sont communiquées que à travers le mail professionnel chiffré, le mot de passe de déchiffrement par SMS.
Les données à accès restreint ne peuvent être partagées qu'à travers une plateforme de partage interne.
- Article 17 :** Si une violation de l'Article 01 conduit à une faille de sécurité, l'employé peut être tenu responsable des dommages causés.
- Article 18 :** Toute violation de l'Article 04 entraînera l'exclusion de l'accès aux fonctions de gestion d'inscription pour une période définie.
- Article 19 :** Toute violation de l'Article 06 entraînera des poursuites judiciaires potentielles pour non-respect des normes réglementaires (amendes, sanctions).
- Article 20 :** Toute violation de l'Article 08 entraînera l'exclusion de l'enseignant des procédures d'évaluation pour une période définie avec une possibilité de poursuite judiciaire en cas de modifications frauduleuses.
- Article 21 :** Toute violation de l'Article 11 entraînera des amendes financières et d'éventuelles poursuites judiciaires.
- Article 22 :** Tout clic sur un lien suspect ou non déclaré (violation de l'Article 13) entraînera un avertissement formel de l'employé concerné.
- Article 23 :** Toute activation des mises à jour automatiques non autorisée (l'Article 14) sera issue d'un avertissement formel de l'employé concerné.
- Article 24 :** Toute modification non justifiée des données sensibles (l'Article 15) entraînera la poursuite des procédures administratives pour déterminer les responsabilités.
- Article 25 :** Toute violation des dispositions de l'Article 16 conduit à une mise à pied de sept (7) jours avec une possibilité de poursuite judiciaire en cas de dégât grave.

3 Plan de Continuité d'Activité (PCA)

Recommandation :

Mettre en place des sauvegardes régulières, externalisées et testées.

Identification des Actions :

1. Préparation de l'environnement.
2. Lancer la sauvegarde.
3. Lancer la restauration en cas d'incident.

Conception de la procedure

3.1 Proc PCA1 : Sauvegarde et Restauration des Données

- **Élément déclencheur** : Risque imminent ou perte partielle/complète des données.
 - **Description** : Garantir la sauvegarde régulière et sécurisée des données critiques ainsi que leur restauration rapide en cas d'incident, minimisant ainsi les interruptions et pertes potentielles..
 - **Processus** :
 1. **Préparation de l'environnement** :
 - (a) Lister les bases de données critiques à sauvegarder.
 - (b) Configurer les sauvegardes sur un espace sécurisé (serveur de secours, cloud).
 - (c) Créer une alerte pour signaler les échecs de sauvegarde
 2. **Lancer la sauvegarde.**
 - (a) Planifier des sauvegardes incrémentales toutes les 24 heures.
 - (b) Réaliser des sauvegardes complètes hebdomadaires.
 - (c) Chiffrer les fichiers sauvegardés avec des clés uniques.
 3. **Lancer la restauration en cas d'incident (Voir PRA XX)** :
 - (a) Déclencher le processus de restauration en cas d'incident.
 - (b) Vérifier l'intégrité des données restaurées.
 - (c) Informer les parties prenantes de la réussite ou des échecs du processus.
-

Recommandation :

Mettre en place une surveillance continue des activités sur les serveurs.

Identification des Actions :

1. Mise en place de la surveillance.
2. Exploitation de la surveillance.
3. Réaction aux alertes.
4. Suivi et amélioration.

Conception de la procédure

3.2 Proc PCA2 : Surveillance Continue des Activités

- **Élément déclencheur** : Configuration initiale ou détection d'une anomalie.
 - **Description** : Surveiller en temps réel les serveurs pour détecter les anomalies, activer des alertes automatiques et réagir rapidement aux incidents pour protéger les données et assurer la continuité du service.
 - **Processus** :
 1. **Mise en place de la surveillance** :
 - (a) Installer et configurer un outil de surveillance continue.
 - (b) Paramétrer les seuils critiques pour des indicateurs comme l'utilisation CPU, RAM, et activité réseau.
 - (c) Associer des alertes aux comportements anormaux (tentatives de connexion échouées, activités inhabituelles, etc.).
 2. **Exploitation de la surveillance** :
 - (a) Collecter en temps réel les journaux d'activité des serveurs.
 - (b) Centraliser ces journaux dans une plateforme sécurisée pour faciliter l'analyse.
 - (c) Générer des rapports hebdomadaires sur l'état des serveurs.
 3. **Réaction aux alertes** :
 - (a) Identifier l'origine des alertes et vérifier leur criticité.
 - (b) Isoler les composants ou connexions suspectes pour éviter la propagation de l'incident.
 - (c) Si nécessaire, activer la procédure PRA associée.
 4. **Suivi et amélioration** :
 - (a) Réaliser un audit mensuel des règles et paramètres de surveillance.
 - (b) Ajuster les seuils critiques en fonction des observations et tendances.
 - (c) Former régulièrement les équipes IT sur les mises à jour des outils de monitoring.
-

Recommandation :

Mettre en place un chiffrement des données sensibles (en transit et au repos).

Identification des Actions :

1. Identification et classification des données.
2. Mise en oeuvre du chiffrement.
3. Surveillance et maintenance.
4. Formation des équipes.

Conception de la procédure

3.3 Proc PCA03 : Chiffrement des Données Sensibles

- **Élément déclencheur :** Création ou traitement de données sensibles.
 - **Description :** Implémenter un chiffrement robuste des données sensibles, en transit et au repos, pour garantir leur confidentialité et intégrité, avec une gestion sécurisée des clés et des audits réguliers.
 - **Processus :**
 1. **Identification et classification des données :**
 - (a) Déterminer quelles données nécessitent un chiffrement (PII, paiements, etc.).
 - (b) Classifier les données selon leur sensibilité et leur utilisation.
 2. **Mise en oeuvre du chiffrement :**
 - (a) Appliquer le chiffrement AES-256 pour les données au repos.
 - (b) Configurer TLS 1.3 ou supérieur pour les communications réseau.
 - (c) S'assurer que les clés de chiffrement sont stockées de manière sécurisée (HSM ou équivalent).
 3. **Surveillance et maintenance :**
 - (a) Effectuer des audits périodiques pour s'assurer que les données restent protégées.
 - (b) Vérifier la conformité des mécanismes avec les réglementations.
 4. **Formation des équipes :**
 - (a) Sensibiliser les équipes IT et opérationnelles aux bonnes pratiques de chiffrement.
 - (b) Former sur les procédures de gestion des clés et des incidents liés au chiffrement.
-

Recommandation :

Définir une politique de contrôle d'accès.

Identification des Actions :

1. Identification et classification.
2. Mise en place de la politique.
3. Surveillance et mise à jour.
4. Sensibilisation.

Conception de la procédure

3.4 Proc PCA04 : Politique de Contrôle d'Accès

- **Élément déclencheur :** Accès à des ressources sensibles ou changement d'état utilisateur (embauche, départ, promotion).
 - **Description :** Mettre en place une politique de contrôle d'accès basée sur le moindre privilège, l'authentification multi-facteurs, et des audits réguliers pour protéger les ressources sensibles et prévenir les accès non autorisés.
 - **Processus :**
 1. **Identification et classification :**
 - (a) Lister les systèmes, données et applications nécessitant des règles spécifiques de contrôle d'accès.
 - (b) Catégoriser les utilisateurs selon leur rôle (administrateurs, enseignants, étudiants, etc.).
 2. **Mise en place de la politique :**
 - (a) Configurer des accès par rôle en appliquant le principe du moindre privilège.
 - (b) Activer une authentification multi-facteurs pour tous les comptes critiques.
 - (c) Documenter les processus d'attribution, de modification et de révocation des droits d'accès.
 3. **Surveillance et mise à jour :**
 - (a) Réaliser des audits réguliers pour détecter les anomalies et maintenir la conformité.
 - (b) Mettre à jour la politique en fonction des évolutions organisationnelles ou des menaces.
 - (c) Vérifier périodiquement l'efficacité des mécanismes d'authentification et de gestion d'accès.
 4. **Sensibilisation :**
 - (a) Communiquer les responsabilités des utilisateurs concernant leurs identifiants et accès.
-

Recommandation :

Utiliser un antivirus et le maintenir (manuellement) à jour.

Identification des Actions :

1. Installation et configuration.
2. Mises à jour manuelles.
3. Surveillance et réaction.
4. Sensibilisation.

Conception de la procédure

3.5 Proc PCA05 : Utilisation et Maintenance d'un Anti-Virus

- **Élément déclencheur :** Détection de nouvelles menaces ou mise à jour requise par l'éditeur.
 - **Description :** Mettre en place une procédure d'utilisation et de maintenance d'un logiciel anti-virus pour protéger le système contre les menaces, assurer la mise à jour des définitions de virus et réagir efficacement en cas d'incident.
 - **Processus :**
 1. **Installation et configuration :**
 - (a) Installer le logiciel anti-virus sur tous les systèmes.
 - (b) Configurer une analyse automatique hebdomadaire et des notifications pour les détections.
 2. **Surveillance et réaction :**
 - (a) Analyser les rapports générés par l'anti-virus pour détecter des anomalies.
 3. **Mises à jour manuelles :**
 - (a) Planifier des sessions hebdomadaires pour télécharger et appliquer manuellement les dernières définitions de virus.
 - (b) Vérifier la compatibilité des mises à jour avec le système.
 4. **Sensibilisation :**
 - (a) Informer les utilisateurs à ne pas désactiver l'anti-virus et à signaler les alertes.
-

Recommandation :

Effectuer des audits réguliers de sécurité.

Identification des Actions :

1. Planification des audits.
2. Exécution des audits.
3. Analyse des résultats.
4. Implémentation des correctifs.

Conception de la procédure

3.6 Proc PCA06 : Audits réguliers de sécurité

- **Élément déclencheur** : Périodicité définie (semestrielle) ou détection d'un incident majeur.
 - **Description** : Effectuer des audits réguliers de sécurité pour évaluer les vulnérabilités du système, détecter les non-conformités, et renforcer la posture de sécurité globale.
 - **Processus** :
 1. **Planification des audits** :
 - (a) Définir le périmètre, les objectifs, et la fréquence des audits.
 - (b) Désigner une équipe interne ou externe pour mener les audits.
 2. **Exécution des audits** :
 - (a) Identifier les vulnérabilités dans les systèmes, réseaux, et applications.
 - (b) Vérifier la conformité aux politiques internes et aux normes externes.
 3. **Analyse des résultats** :
 - (a) Rédiger un rapport détaillant les faiblesses détectées.
 - (b) Prioriser les vulnérabilités selon leur gravité et impact.
 4. **Implémentation des correctifs** :
 - (a) Élaborer et appliquer des plans d'action pour corriger les vulnérabilités.
 - (b) Réaliser un audit de suivi pour valider les corrections.
-

Recommandation :

Établir un plan de formation et de sensibilisation.

Identification des Actions :

1. Identification des besoins en formation.
2. Élaboration du programme de sensibilisation.
3. Mise en oeuvre des sessions de formation.
4. Évaluation et amélioration continue.

Conception de la procédure

3.7 Proc PCA07 : Plan de Formation et Sensibilisation

- **Élément déclencheur :** Introduction de nouvelles politiques de sécurité, évolution des menaces, ou survenance d'incidents.
 - **Description :** Développer et mettre en oeuvre un programme de formation et de sensibilisation pour renforcer les compétences des utilisateurs en matière de sécurité et garantir leur engagement envers les bonnes pratiques.
 - **Processus :**
 1. **Identification des besoins en formation :**
 - (a) Analyser les risques liés aux activités des utilisateurs.
 - (b) Identifier les lacunes en compétences ou en sensibilisation.
 2. **Élaboration du programme de sensibilisation :**
 - (a) Définir les objectifs pédagogiques et les thématiques prioritaires (ex : phishing, gestion des mots de passe, contrôle d'accès).
 - (b) Préparer le contenu sous divers formats (présentations, vidéos, quiz).
 3. **Mise en oeuvre des sessions de formation :**
 - (a) Planifier des sessions adaptées à chaque groupe d'utilisateurs (administrateurs, enseignants).
 - (b) Assurer la diffusion des supports et l'interactivité des formations.
 4. **Évaluation et amélioration continue :**
 - (a) Évaluer les connaissances acquises via des tests ou questionnaires.
 - (b) Collecter les retours des participants pour améliorer les futures sessions.
-

Recommandation :

Utiliser un firewall.

Identification des Actions :

1. Installation et configuration du firewall.
2. Définition des règles de sécurité.
3. Surveillance continue des activités réseau.
4. Mise à jour et adaptation des règles.

3.8 Proc PCA08 : Utilisation et Gestion d'un Firewall

- **Élément déclencheur :** Introduction de nouveaux services, détection d'activités suspectes, ou modification de l'infrastructure réseau.
 - **Description :** Mettre en place un firewall pour protéger les systèmes contre les intrusions, surveiller les flux réseau, et adapter les règles en fonction des évolutions des menaces.
 - **Processus :**
 1. **Installation et configuration :**
 - (a) Installer le firewall sur les points stratégiques du réseau (passerelles, serveurs critiques).
 - (b) Configurer des règles de base pour bloquer le trafic non autorisé.
 2. **Définition des règles de sécurité :**
 - (a) Analyser les besoins réseau pour établir des politiques adaptées (e.g., autorisation par IP, port ou protocole).
 - (b) Implémenter des règles restrictives basées sur le principe du moindre privilège.
 3. **Surveillance continue :**
 - (a) Analyser les journaux d'activité pour détecter des tentatives d'intrusion ou des anomalies.
 - (b) Configurer des alertes en temps réel pour les événements critiques.
 4. **Mise à jour et adaptation :**
 - (a) Mettre régulièrement à jour les règles en fonction des nouvelles menaces ou des changements d'infrastructure.
 - (b) Tester les modifications pour garantir la continuité des services.
-

Recommandation :

Déployer des serveurs de secours avec un mécanisme de basculement automatique pour assurer la continuité des services en cas de panne du système principal.

Identification des Actions :

1. Évaluation et planification.
2. Configuration des serveurs de secours.
3. Mise en place du mécanisme de basculement automatique.
4. Tests, surveillance, et maintenance continue.

Conception de la procédure

3.9 Proc PCA9 : Déploiement de Serveurs de Secours et Basculement Automatique

- **Élément déclencheur :** Défaillance du serveur principal, maintenance planifiée ou augmentation soudaine de la charge.
 - **Description :** Implémenter des serveurs de secours avec un processus de basculement automatique pour garantir que les services critiques restent opérationnels même en cas de panne du système principal.
 - **Processus :**
 1. **Évaluation et planification :**
 - (a) Identifier les services critiques nécessitant une continuité immédiate.
 - (b) Évaluer les besoins en termes de capacité des serveurs de secours (CPU, mémoire, stockage).
 - (c) Choisir une solution adaptée pour le basculement automatique (par ex. : cluster haute disponibilité, load balancer).
 2. **Configuration des serveurs de secours :**
 - (a) Installer et configurer les serveurs secondaires dans un site de secours ou un environnement cloud.
 - (b) Synchroniser les données en temps réel entre les serveurs principaux et les serveurs de secours.
 - (c) Mettre en place des sauvegardes régulières pour les données critiques.
 3. **Mise en place du mécanisme de basculement automatique :**
 - (a) Configurer un système de détection des pannes (ex. : surveillance via un outil comme Nagios ou Zabbix).
 - (b) Automatiser la redirection des requêtes vers les serveurs de secours en cas de panne (DNS failover, scripts de basculement).
 - (c) Tester la rapidité et l'efficacité du basculement dans divers scénarios (panne réseau, surcharge, défaillance matérielle).
 4. **Tests, surveillance, et maintenance continue :**
 - (a) Effectuer des tests réguliers pour vérifier que les serveurs de secours prennent bien le relais en cas de panne.
 - (b) Surveiller les performances des serveurs principaux et secondaires.
 - (c) Mettre à jour les configurations en fonction des évolutions technologiques ou des besoins accrus.
-

Recommandation :

Créer un processus clair de gestion des incidents (prévention, détection, réponse).

Identification des Actions :

1. Évaluation et planification.
2. Mise en place des mécanismes de prévention.
3. Détection et analyse des incidents.
4. Réponse et résolution des incidents.
5. Amélioration continue.

Conception de la procédure

3.10 Proc PCA:10 Gestion des Incidents (Prévention, Détection, Réponse)

- **Élément déclencheur :** Survenue d'un incident ou identification d'une menace potentielle.
 - **Description :** Créer un processus structuré pour prévenir, détecter, et répondre efficacement aux incidents de sécurité informatique en intégrant des outils et des procédures adaptés.
 - **Processus :**
 1. **Évaluation et planification :**
 - (a) Identifier les types d'incidents susceptibles de se produire.
 - (b) Cartographier les actifs critiques et les risques associés.
 - (c) Élaborer un plan d'intervention basé sur des scénarios réalistes.
 2. **Mise en place des mécanismes de prévention :**
 - (a) Déployer des solutions de protection telles que pare-feu, systèmes de détection d'intrusion (IDS/IPS) et anti-virus.
 - (b) Mettre en oeuvre une politique de formation et de sensibilisation des utilisateurs.
 - (c) Effectuer régulièrement des audits et des tests de pénétration pour identifier les failles.
 3. **Détection et analyse des incidents :**
 - (a) Configurer des systèmes de journalisation et de monitoring pour détecter les anomalies.
 - (b) Établir des indicateurs clés pour évaluer l'impact potentiel des incidents.
 - (c) Utiliser des outils de corrélation d'événements (SIEM) pour une analyse rapide et approfondie.
 4. **Réponse et résolution des incidents :**
 - (a) Activer un plan d'intervention en cas d'incident (Playbook).
 - (b) Réaliser des enquêtes post-incident pour comprendre l'origine et l'étendue des dommages.
 5. **Amélioration continue :**
 - (a) Documenter les incidents et les leçons apprises.
 - (b) Mettre à jour les procédures et les outils pour éviter des incidents similaires.
 - (c) Réaliser des exercices réguliers pour tester la robustesse du processus.
-